Independent Privacy and Information Security Report: [Customer Redacted]

This report was produced for [Customer Redacted] (the Club)
[Website Redacted]

By

Andrew Wilkinson (the Author)
https://www.linkedin.com/in/andrew-wilkinson-540a54106/
contact@adaptive.nz

Published version 1.2 2025-03-02

Contents

Section	Page
1. Report Objectives & Scope	2
2. Disclaimers	3
3. Key Recommendations	4
4. Analysis & Findings	5
____4.1 Privacy	5
____4.2 Information Security	7
5. Recommendations	15
6. Sources	18

1. Report Objectives & Scope

The purpose of this report is to provide actionable recommendations for the board of the Club, specifically relating to the topics of privacy and information security.

Analysis was focused on low-maturity best practices ("the basics") in both areas; these best practices are usually organisation-agnostic, and generally have good cost-benefit ratios.

The scope of the analysis is restricted to requirements and practices relevant to New Zealand. The assumption was made that the Club does not operate in, or collect data from, other countries. Therefore, requirements derived from overseas regulation such as GDPR were not considered.

The analysis conducted for this report does not constitute a review of the Club's IT infrastructure or a penetration test. Physical security, such as locks and cameras, is out of scope for this report.

This report was compiled based on limited information on the Club's activities. However, given the report is focused on low-maturity best practices for privacy and security, the Author does not consider this a limitation. Should the Club wish to pursue further maturity in either area, the

Author recommends a higher level of engagement and context for any entity providing the Club with advice.

The Author is not a lawyer and this report does not constitute legal advice.

Further information and clarification can be requested via contact@adaptive.nz.

2. Disclaimers

- The Club should seek professional advice from a lawyer on legal and regulatory obligations specific to the Club.
- The recommendations outlined within this document do not guarantee compliance, nor do they guarantee absolute protection against privacy or security incidents.
- The recommendations outlined within this document are the professional opinion of the Author, and do not represent the opinions of the Author's employer.
- This report is the Author's personal work and is not the property of the Author's employer.
- The information in this report is correct to the best of the Author's knowledge at time of writing.
- This report was written by a human. An LLM (Claude) assisted in finding inconsistencies, making suggestions, and document styling/formatting, but did not directly contribute to the substance of this report.

3. Key Recommendations

This is not an exhaustive list of recommendations; see the Recommendations section below. The purpose of this section is essentially "if you don't read anything else, please read this".

1. **Focus on doing "the basics" well first.** For example - ensure the Club's email accounts all have multi-factor authentication enabled before requesting a comprehensive security review of the Club's IT. The recommendations in this report focus on the basics.
2. **Appoint a Privacy Officer** - this is a legal requirement for the Club. The Office of the Privacy Commissioner provides free e-learning for Privacy Officers to acquaint themselves with their responsibilities: https://www.privacy.org.nz/resources-and-learning/online-privacy-training-free/
3. **Add a Privacy Statement to the Club's website.** The Office of the Privacy Commissioner provides a Privacy Statement generator free of charge: https://www.privacy.org.nz/responsibilities/privacy-statement-generator/
    1. As an example: https://www.privacy.org.nz/about-us/website-privacy-statement/
4. **Ensure multi-factor authentication (also known as MFA or 2FA) is enabled** on all Club email accounts, and ideally on all Club-related web logins.
    1. Google Authenticator (https://support.google.com/accounts/answer/1066447) is a serviceable application for multi-factor authentication, but if the Club is already using something else, continue using that.
5. For login credentials related to the Club, **make use of a password manager,** rather than using the in-built browser password managers that come with Chrome/Edge/Firefox, as these are vulnerable to credential harvesting attacks that steal usernames and passwords.
    1. Bitwarden (https://bitwarden.com/) is a serviceable password manager but if the Club is already using something else, continue using that.

4. Analysis & Findings

4.1 Privacy

4.1.1 Privacy Officer

Noting again that the Author is not a lawyer and this is not legal advice: the Club is legally required to comply with the Privacy Act, and is legally required to appoint a Privacy Officer.

A Privacy Officer is a role in an organisation held by an individual, but in many organisations it is a role held by an existing officer or employee, rather than a dedicated hire.

The Privacy Officer must be familiar with the 13 Information Privacy Principles from the Privacy Act, and how they apply to the Club. They must also take responsibility for ensuring the Club has processes in place to adhere to these principles, and they are expected to be the main point of contact for the Office of the Privacy Commissioner should a privacy breach at the Club occur.

The Office of the Privacy Commissioner provides free e-learning for Privacy Officers to acquaint themselves with their responsibilities: https://www.privacy.org.nz/resources-and-learning/online-privacy-training-free/

4.1.2 Privacy Statement on Club Website

The Club website ([Website Redacted]) does not appear to have a Privacy Statement advising users how their data is collected and managed. As an example: https://www.privacy.org.nz/about-us/website-privacy-statement/

While this is not a legal requirement, it is a simple way to demonstrate the principle of Transparency as part of the Club's Privacy Act obligations.

The Office of the Privacy Commissioner provides a Privacy Statement generator free of charge: https://www.privacy.org.nz/responsibilities/privacy-statement-generator/

4.1.3 Collection, Retention, and Disclosure of Personal Information

The following is a summary from a layperson (i.e. not a lawyer) of relevant points from the Information Privacy Principles section of the Privacy Act.

- Personal information is information about any identifiable individual.
- Don't collect personal information unless there is a legitimate reason for doing so that aligns with the function of your organisation.
- Collect personal information from the individual concerned wherever possible (i.e. not from a third party).
- The person whose information is being collected should be aware it is happening before it happens.
- Take all reasonable steps to protect the personal information that has been collected.
- Individuals are entitled to request access or corrections to the personal information you hold on them.
- Don't keep personal information for longer than necessary ("necessary" aligning with the legitimate reason for collecting the information).
- Don't use personal information for a purpose that it wasn't collected for.
- Don't disclose personal information to third parties, unless that disclosure is specifically related to the purpose for which the information was collected.
- Ensure personal information is correct before disclosing that information to third parties.
- If disclosing personal information to an entity overseas, inform the individual it was collected from wherever possible, ideally before collection.
- Try to avoid assigning unique identifiers to individuals from whom you collect personal information. For example - don't collect IRD numbers if they aren't necessary for the organisation to function.

4.1.4 Data Minimisation

Don't collect personal information, or any other data, that isn't necessary for the organisation to function.

Once data is no longer needed, delete it. For example - if a copy of an identity document is required for member signup, consider deleting these copies after the individual has held their membership for a certain period of time.

In minimising data collection and retention, the Club can reduce the impact of potential data breaches, and ease the administrative burden of the Privacy Officer.

4.1.5 EU General Data Protection Regulation (GDPR)

GDPR is not New Zealand law, and (unless the Club frequently provides services to EU Citizens, and "frequently" would be more than the occasional member who happens to have EU citizenship) does not apply to the club.

It is being mentioned here primarily because the ubiquitous "Accept/Reject Cookies" popups on websites across the globe are a result of GDPR being enforced. The Club does not need to add such a popup to their website.

The Office of the Privacy Commissioner has a good summary on NZ compliance with GDPR here: https://www.privacy.org.nz/resources-and-learning/knowledge-base/view/480/

4.1.6 Backups of Personal Information

Where personal information is backed up, ensure those backups are just as secure as the place the data is primarily being held.

For example - if personal information in the member portal has database encryption and multi-factor authentication access for admins, both of those controls should be present in the system the data is backed up to.

4.2 Information Security

4.2.1 Main Information Security Threats

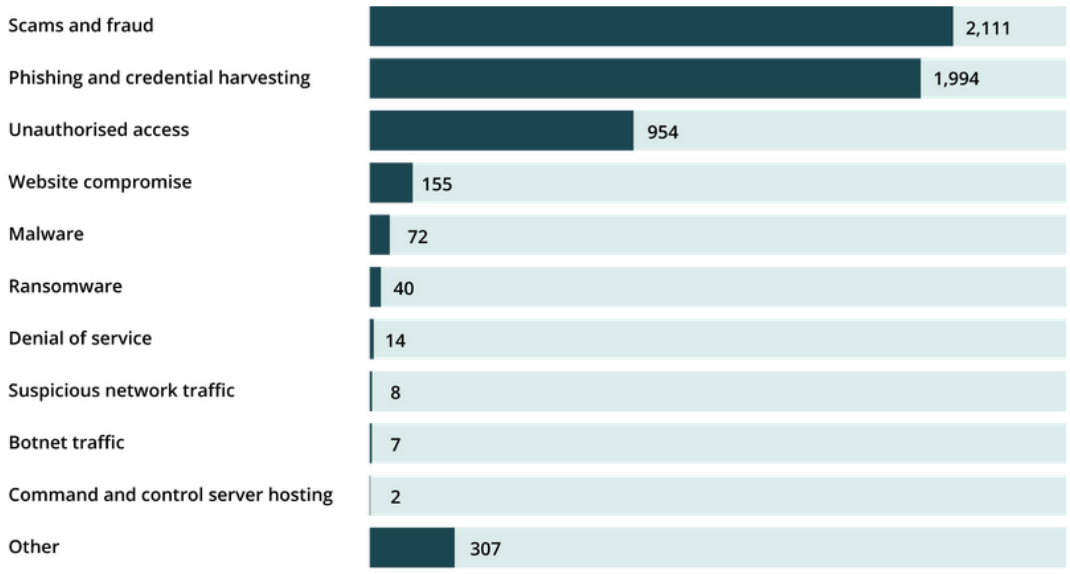
The main security threats for the Club to consider are:

1. Scams and Fraud - attempts to deceive, impersonate, divert payments.
2. Phishing and Credential Harvesting - email or SMS delivery of content to persuade the user to click malicious links, often downloading malicious software that harvests usernames and passwords from the device.

The National Cyber Security Center (NCSC) has a lot of helpful information for organisations looking to evaluate and improve their information security maturity.

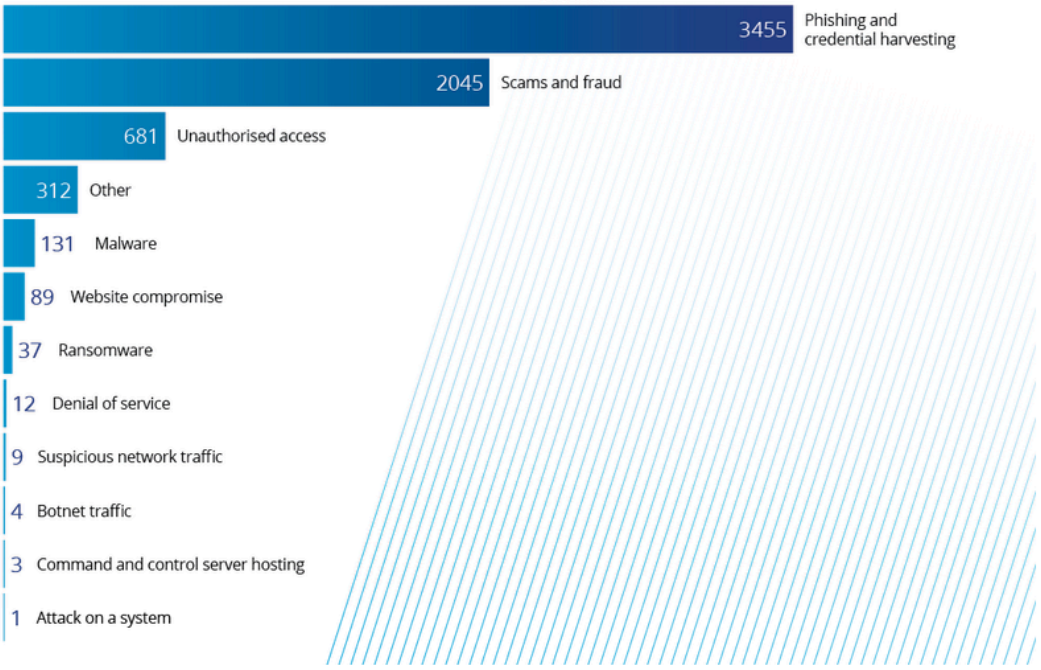
The NCSC's 2024/25 threat report data shows scams, fraud, phishing and credential harvesting are the most statistically significant threats for the Club to consider. The analysis in this report will focus on finding actionable recommendations for the Club to address these threats.

From https://www.ncsc.govt.nz/insights-and-research/cyber-threat-reports/cyber-threat-report-2025/incident-reporting-analysis/



Source & Credit: National Cyber Security Centre (NCSC), Cyber Threat Report 2024/25

This is corroborated by the data NCSC has specifically on incidents usually affecting individuals and small to medium businesses: https://www.ncsc.govt.nz/insights-and-research/cyber-threat-reports/20232024-cyber-threat-report/incidents-usually-affecting-individuals-or-small-to-medium-businesses/



Source & Credit: National Cyber Security Centre (NCSC), Incidents usually affecting individuals or small to medium businesses

4.2.2 Scams and Fraud

Scams and Fraud usually rely on/exhibit a few common approaches:

- Creating a sense of urgency, to attempt to short-circuit rational thinking processes,
- Use of legitimate pieces of information, often publicly available but add to the credibility of the scammer, and/or
- Generic greetings from organisations that know your name (like your bank).

The NCSC has a good article that is specifically related to banking fraud but is broadly applicable: https://www.ncsc.govt.nz/insights-and-research/insights-reports/quarter-four-cyber-security-insights-2024/hello-this-is-your-bank/

There are three basic ways the Club can improve their protection against scams and fraud:

1. Enable multi-factor authentication on all systems that contain data or functionality that would be valuable to a scammer. Usually:

    1. Bank portals and apps
    2. Email accounts
    3. Logins to member/administration portals

2. Add a second approver for large financial transactions and changes to payment details (e.g. a supplier asking the Club to pay to a different bank account).
    1. Ideally "out of band" - e.g. if you get an email from a supplier asking to change their bank account, confirm it on a phone call.

3. General security awareness training for Club staff. The Club may be able to get pro bono services from an organisation like Kordia for this (https://www.kordia.co.nz/education-and-training).
    1. The Author is not employed by or associated with Kordia at time of writing. The Club should select a provider that best suits their needs.

This does not guarantee 100% protection against scams and fraud - however, these recommendations will significantly reduce the likelihood and impact of these situations.

4.2.3 Phishing and Credential Harvesting

"Phishing", a play on the word fishing, is one of the most common methods for attackers to attempt to extract value from organisations. Phishing emails have commonalities with fraud and scams:

- Creating a sense of urgency, to attempt to short-circuit rational thinking processes,
- Use of legitimate pieces of information, often publicly available but add to the credibility of the scammer, and/or
- Generic greetings from organisations that know your name (like your bank).

The "hook" of a phishing email is usually a malicious URL that looks benign or legitimate. The nature of the malicious URL varies depending on the goals of the attacker.

One of the more common attacks the NCSC is observing is credential harvesting, where attackers deliver malicious software to a device (often via

a phishing email), where sensitive data is harvested and sent back to the attacker to be used or sold.

Data harvested in these attacks commonly includes:

- Usernames and passwords saved in browser password managers, including Chrome, Edge, and Firefox
- Usernames and passwords saved in text files
- Personal information saved in text files (name, address, date of birth)
- Anything that looks like a copy of a government issued ID, like a passport or drivers license

Fortunately, "the basics" for protecting the Club against phishing and credential harvesting have significant overlap with scams and fraud:

1. Enable multi-factor authentication on all systems that contain data or functionality that would be valuable to an attacker. Usually:
    1. Bank portals and apps
    2. Email accounts
    3. Logins to member/administration portals
2. General security awareness training for Club staff. The Club may be able to get pro bono services from an organisation like Kordia for this (https://www.kordia.co.nz/education-and-training).
    1. The Author is not employed by or associated with Kordia at time of writing. The Club should select a provider that best suits their needs.
3. For login credentials related to the Club, make use of a password manager, rather than using the in-built browser password managers that come with Chrome/Edge/Firefox.
    1. Bitwarden (https://bitwarden.com/) is a serviceable password manager but if the Club is already using something else, continue using that.
    2. The Author is not employed by or associated with Bitwarden at time of writing. The Club should select a password manager that best suits their needs.

The NCSC provides some helpful information on multi-factor authentication here: https://www.ncsc.govt.nz/protect-your-organisation/multi-factor-authentication-and-verification/

And information on password managers here: https://www.ncsc.govt.nz/protect-your-organisation/password-managers/

4.2.4 Patching and Updates

Attackers frequently exploit unpatched vulnerabilities in websites and software. The most relevant situation for the Club can be summarised as follows:

- Someone discovers a vulnerability in a piece of software
- The vendor fixes ("patches") that vulnerability, and releases the update to the public
- The update is made available on the user's device
- The user declines the update because it's inconvenient
- The user's device is then exploited through the unpatched vulnerability, and value is lost

Put simply - the Club should put processes in place to keep up with software and operating system updates. Delaying updates for a few days is fine, but the longer updates are declined/deferred the greater the risk the device in question could be exploited.

The Club has an opportunity to put processes in place to check that local and directly engaged vendors have good patching processes. For example - how does Friendly Manager (the vendor for the Club website) ensure that vulnerabilities in their web application are promptly patched? This is an opportunity, not a recommendation, because it is at a slightly higher level of maturity than "the basics" this report is focused on.

4.2.5 Endpoint Protection

What used to be called "Antivirus" tools have rapidly and diversely evolved into various different types of protection. While it was once common to install free or paid antivirus software, this is no longer recommended.

For large organisations, or those with mature information security functions, there are enterprise-grade endpoint detection products available.

For small to medium organisations, the out-of-the-box Windows and macOS protection tools are sufficient, and on-par with paid solutions: https://www.av-test.org/en/antivirus/home-windows/

For virus and malware protection, the Club should put processes in place to ensure:

1. Windows Defender is enabled, and stays enabled, on all Windows workstations.
2. Gatekeeper is enabled (App Store and identified developers setting), and stays enabled, on all macOS workstations.

4.2.6 Backups

While not as prevalent as the aforementioned threats, ransomware is a threat worth some brief attention by the Club. This usually involves an attacker gaining access to a system or device, extracting valuable or sensitive data, then forcibly encrypting the files on the device. The attacker then attempts to force the target to pay a ransom in order to unlock the files and prevent the valuable/sensitive data from being leaked.

While ransomware incidents can be complex, from a business continuity perspective the first step is ensuring that data required for the organisation to continue operations is backed up on a separate system from which it operates.

Good practice is the 3-2-1 rule:

- Three copies
- Two different kinds of media (e.g. one cloud, one hard drive)
- One off-site (in case of events like fires)

The Club should evaluate what is critical to continued operations, and ensure the data remains available should an event like ransomware occur.

4.2.7 Application Security Review

Notably, the Author is not an application security specialist, and as such can't make any substantial recommendations here.

However - member and admin portals are common targets for attackers, and the Club should

1. Ask the vendor ([Vendor Redacted] if they get regular penetration tests of their application, and,
2. Consider having an independent penetration test done if the vendor is not doing this themselves.

There are several organisations in New Zealand capable of doing this to a good standard, like ZX Security: https://zxsecurity.co.nz/services/penetration-testing/

- The Author is not employed by or associated with ZX Security at time of writing.

4.2.8 Ongoing Maturity

The NCSC has a Minimum Security Standards document (https://www.ncsc.govt.nz/protect-your-organisation/minimum-standards/) that covers best practice across different levels of maturity.

While it's unlikely this document is immediately useful for the Club, if the Club wished to track their ongoing maturity in information security, this is the standard the Author recommends to achieve that.

5. Recommendations

Focus on doing "the basics" well first. For example - ensure the Club's email accounts all have multi-factor authentication enabled before requesting a comprehensive security review of the Club's IT. The recommendations in this report focus on the basics.

5.1 Privacy Recommendations

Numbered for convenience (i.e. not an external reference to something else).

- **P01**: Appoint a Privacy Officer - this is a legal requirement for the Club. The Office of the Privacy Commissioner provides free e-learning for Privacy Officers to acquaint themselves with their responsibilities: https://www.privacy.org.nz/resources-and-learning/online-privacy-training-free/
- **P02**: Have that Privacy Officer complete the e-learning course provided by the Office of the Privacy Commissioner.
- **P03**: In the duties of the appointed Privacy Officer, include the compilation of an annual Privacy Officer report for the Club board. This report should include:
    - A summary of privacy-related activities carried out through the year,
    - Recommendations for improvements to privacy-related processes for the board to review, and
    - Details of any breaches or interactions with the Office of the Privacy Commissioner.
- **P04**: Add a Privacy Statement to the Club's website, using the privacy statement generator provided by the Office of the Privacy Commissioner.

5.2 Security Recommendations

Numbered for convenience (i.e. not an external reference to something else).

- **S01**: Ensure multi-factor authentication (also known as MFA or 2FA) is enabled on all Club email accounts, and ideally on all Club-related web

logins.

  - Google Authenticator (https://support.google.com/accounts/answer/1066447) is a serviceable application for multi-factor authentication, but if the Club is already using something else, continue using that.

- **S02**: For login credentials related to the Club, make use of a password manager, rather than using the in-built browser password managers that come with Chrome/Edge/Firefox, as these are vulnerable to credential harvesting attacks that steal usernames and passwords.
  - Bitwarden (https://bitwarden.com/) is a serviceable password manager but if the Club is already using something else, continue using that.

- **S03**: General security awareness training for Club staff. The Club may be able to get pro bono services from an organisation like Kordia for this (https://www.kordia.co.nz/education-and-training).
- **S04**: The Club should put processes in place to keep up with software and operating system updates. Delaying updates for a few days is fine, but the longer updates are declined/deferred the greater the risk the device in question could be exploited.
- **S05**: For virus and malware protection, the Club should put processes in place to ensure:
  1. Windows Defender is enabled, and stays enabled, on all Windows workstations.
  2. Gatekeeper is enabled (App Store and identified developers setting), and stays enabled, on all macOS workstations.

- **S06**: The Club should evaluate what is critical to continued operations, and ensure the data remains available should an event like ransomware occur.
  - Good practice is the 3-2-1 rule:
    - Three copies
    - Two different kinds of media (e.g. one cloud, one hard drive)
    - One off-site (in case of events like fires)

- **S07**: Member and admin portals are common targets for attackers, and the Club should

1. Ask the vendor (Friendly Manager) if they get regular penetration tests of their application, and,
2. Consider having an independent penetration test done if the vendor is not doing this themselves.
3. There are several organisations in New Zealand capable of doing this to a good standard, like ZX Security: https://zxsecurity.co.nz/services/penetration-testing/

6. Sources

- https://www.legislation.govt.nz/act/public/2020/0031/latest/LMS23223.html
- https://www.privacy.org.nz/
  - https://www.privacy.org.nz/responsibilities/privacy-statement-generator/
  - https://www.privacy.org.nz/resources-and-learning/knowledge-base/view/480/
- https://www.ncsc.govt.nz/
  - https://www.ncsc.govt.nz/protect-your-organisation/minimum-cyber-security-standards/
  - https://www.ncsc.govt.nz/protect-your-organisation/password-managers/
  - https://www.ncsc.govt.nz/protect-your-organisation/multi-factor-authentication-and-verification/
  - https://www.ncsc.govt.nz/insights-and-research/cyber-threat-reports/cyber-threat-report-2025/incident-reporting-analysis/
  - https://www.ncsc.govt.nz/insights-and-research/cyber-threat-reports/20232024-cyber-threat-report/incidents-usually-affecting-individuals-or-small-to-medium-businesses/
  - https://www.ncsc.govt.nz/insights-and-research/insights-reports/quarter-four-cyber-security-insights-2024/hello-this-is-your-bank/
- https://www.av-test.org/en/antivirus/home-windows/